

PRODUCT REQUIREMENTS DOCUMENT

Least Data Banking Protocol

Privacy-by-Design API Infrastructure for Intent-Based Banking

PRD v1.0 • API Spec v1.0.0

Author	Mary Ann Belarmino
Organization	BelarminoAdvisory.com
Document Type	Product Requirements Document (PRD)
Status	v1.0 — Ready for Stakeholder Review
API Spec Ref	LDBP OpenAPI v1.0.0 (ldbp_api.yaml)
Whitepaper Ref	The End of All-Access Banking: Moving Toward a Least Data Banking Protocol (v1.0 RFC)
License	CC BY 4.0
Last Updated	April 2026

Classification Notice

This document contains original protocol architecture and design authored by Mary Ann Belarmino (BelarminoAdvisory.com) and licensed under Creative Commons Attribution 4.0 International (CC BY 4.0). You are free to share and adapt this work for any purpose, including commercial, provided attribution to Mary Ann Belarmino and BelarminoAdvisory.com is clearly stated. Attribution must be preserved in all copies, implementations, derivative works, and references.

1. Executive Summary

Every time a user links a bank account to a Finance App, they may unknowingly grant that app persistent access to their accounts, transaction history, and balances — far beyond what any single transaction requires. This is not a fringe vulnerability. It is the documented behavior of major financial aggregators operating in the US market today, as confirmed by a \$58 million class action settlement against Plaid in 2022 for collecting and profiting from user financial data without meaningful consent.

The Least Data Banking Protocol (LDBP) is a bank-side open standard. A bank implements it once. Any Finance App—regardless of category, size, or use case—connects to the same Boolean verification interface without requiring app-side protocol changes. LDBP eliminates this problem at the architectural layer. Rather than asking "how do we restrict what Finance Apps do with the data they extract?", LDBP asks a different question: "what if the Finance App never received the data in the first place?"

The answer is Boolean verification — the "is_enough" check. Instead of returning a raw balance of \$1,402.21, LDBP's `POST /balance/verify` endpoint returns a single `True` or `False`: does the scoped account hold sufficient funds for this specific transaction? Nothing else leaves the bank.

This document defines the full product requirements for implementing LDBP, including the Phase 1 Clean Pipe MVP and the Phase 2 Risk Capping and Governance extension. It is the authoritative requirements reference for engineering teams, compliance stakeholders, bank integration partners, and regulatory reviewers.

The Core Shift

From "Data Extraction" to "Insight Verification." LDBP does not restrict what apps do with your data — *it ensures they never receive it*. If apps don't have the data, they cannot lose it in a breach, or use it to profile users for targeted financial products.

2. Problem Statement

2.1 The All-Access Model Is a Structural Privacy Failure

The current financial data-sharing ecosystem was not designed for privacy — it was designed for convenience. The dominant paradigm, perfected by aggregators like Plaid and Yodlee, operates on a principle of "all-or-nothing" access: to verify a \$50 transaction, the app is granted full visibility into the user's entire financial universe.

When a user links their Bank of America checking account to Stripe, the following happens:

- All accounts at that bank — checking, savings, credit card — are exposed to the aggregator.
- 24 months of full transaction history is extracted and stored in the aggregator's database.
- The exact account balance is returned as a raw number — and stored.
- A persistent "pipe" is opened that remains active 24/7 until the user manually revokes it — a step most users never take because they don't know it exists.

- The aggregator's Terms of Service permit using this data for profiling and upselling, and in documented cases, aggregators have shared or monetized user transaction data with third parties.

2.2 The Four Harms

Harm	Who Experiences It	Current Reality	LDBP Outcome
Privacy Violation	Consumer	Full financial history extracted without meaningful consent	Zero history extracted. Boolean only.
Security Exposure	Consumer + Bank	Aggregator data haystacks are prime breach targets	No data to breach at app layer
Fraud Liability	Consumer + Bank	Overlapping, circular fraud responsibility between bank, aggregator, and app	Account-level fraud returns to bank. Clean separation.
Economic Loss	Bank	Transaction data — the bank's primary competitive asset — given to aggregators for free	Bank monetizes via bps royalties on executed transactions

LDBP addresses this at the source. Because it is a bank-side standard, it does not require individual Finance App compliance campaigns. A bank that implements LDBP automatically enforces least-data principles on every Finance App connecting through it—existing, new, or future.

2.3 Why This Is Allowed to Happen

- **Legacy Debt:** Core banking systems (FIS, Fiserv, Jack Henry) were built for batch, all-or-nothing access. Granular scoping does not exist natively.
- **Misaligned Incentives:** Aggregators profit from the data. Banks have historically lacked both the infrastructure and commercial motivation to restrict access.
- **Lack of Alternatives:** Until LDBP, the only choices were full-access APIs or screen scraping. There was no Boolean-verification primitive in the market.
- **Circular Fraud Dependency:** Finance Apps inserted themselves into the fraud detection layer, then cited fraud prevention as justification for all-access data. This is a circular dependency — apps built their fraud models on data collected beyond what any individual transaction required, then cited those models as justification for continued over-collection.

2.4 Regulatory Gap This Fills

CFPB Section 1033 codifies the consumer's right to data portability but leaves a technical vacuum: *it requires data minimization as a legal standard without specifying how minimization is technically enforced.* (Note: As of April 2026, CFPB Section 1033 is subject to ongoing litigation and CFPB reconsideration; LDBP's technical approach remains valid regardless of the rule's litigation status.)

GDPR's Purpose Limitation principle prohibits over-collection but relies on self-certification.

PSD3 bans screen scraping in the EU but does not mandate Boolean-only verification — EU APIs still return raw balances.

LDBP fills this vacuum. It transforms "reasonably necessary" from a legal assertion into a technical guarantee. When the bank's PEP returns only a Boolean, over-collection becomes technically impossible — not just contractually prohibited.

3. Goals & Non-Goals

3.1 Goals

Goal ID	Goal Statement
G-01	Eliminate raw balance and transaction history exposure to third-party Finance Apps.
G-02	Implement composite atomic verification: balance check and fraud evaluation in a single locked PEP operation.
G-03	Enforce account-level scoping: one user-selected account per token, with hard architectural rejection of out-of-scope requests.
G-04	Restore notification sovereignty: bank notifies user directly on blocked verifications; the Finance app receives only <code>False</code> .
G-05	Enable bank monetization: basis-point royalties on execution events, with optional metering of verification calls at institution discretion.
G-06	Achieve Phase 1 compliance at a 6–9 month engineering LOE without requiring core ledger replacement.
G-07	Provide a compliant technical interface for CFPB Section 1033, GDPR Purpose Limitation, and PSD3 mandates.
G-08	Establish the correct authorization primitive for agentic and multi-agent financial operations.

3.2 Non-Goals

Non-Goal	Rationale
Replace core banking ledger systems	LDBP is a Translation & Governance Layer that sits on top of existing cores. Full ledger replacement is not required.
Mandate specific fraud scoring algorithms	Fraud model internals are implementation-defined. LDBP mandates the architectural boundary, not the algorithm.
Define consumer notification UI/UX	Delivery channel and visual format for verification.blocked events are institution-defined.
Set Weekly/Monthly allowance cap values	Cap values are user-configured and institution-implemented. LDBP specifies the mechanism.

Serve as a credit underwriting standard	BNPL and credit products require a separate bank-mediated creditworthiness signal specification (designated for a future version).
Provide a complete anti-fraud system	LDBP provides the architectural boundary for fraud responsibility. Full fraud detection infrastructure is a bank-side responsibility.

4. Personas & Use Cases

4.1 Primary Personas

Persona	Description	Primary Need
Bank API Architect	Technical lead at a US retail bank responsible for developer interfaces and 1033 compliance posture.	A compliant, low-LOE API gateway spec they can implement on top of FIS/Fiserv/Jack Henry without a core replacement project.
Finance App Developer	Engineer at any payment processor, P2P app, BNPL provider, investment platform, or gig economy wallet connecting to an LDBP-compliant bank. Finance Apps are consumers of the LDBP interface, not implementers of it.	A standard Boolean verification API contract that works identically regardless of which LDBP-compliant bank is connected. Reduces data liability and NSF decline rates without app-side protocol changes.
Bank Compliance Officer	Regulatory and legal stakeholder responsible for CFPB 1033, GDPR, PSD3, and Reg E posture.	A documented technical mapping between LDBP protocol behaviors and specific regulatory requirements.
End Consumer	User linking a bank account to a Finance App. Non-technical.	Confidence that linking a bank account does not expose their entire financial life. A Kill Switch they can actually find and use.
AI Agent / Agentic System	An autonomous agent or multi-agent system authorized to execute financial operations on a user's behalf.	A least-privilege authorization primitive that scopes each financial action to its declared intent without accumulating account state.

4.2 Core Use Cases

UC-01: One-Time Purchase Verification

A consumer purchases a \$50 item from an e-commerce merchant that uses Stripe as its payment processor.

1. Consumer initiates checkout and selects "Pay with Bank Account."
2. Consumer authenticates with their bank via the LDBP-compliant account selector UI.
3. Consumer selects their Checking account. Bank issues a ScopedAccountToken restricted to that account.

4. Stripe generates an Intent-ID for the \$50 transaction and calls `POST /balance/verify`.
5. Bank's PEP atomically checks balance sufficiency AND evaluates fraud risk. Returns `True`.
6. Stripe calls `POST /transfer/charge` with the same Intent-ID.
7. Bank atomically re-verifies and executes. Transfer completes.
8. Consumer receives bank notification: "\$50 authorized to Stripe [Merchant Name]."

Privacy Outcome

Stripe receives: `True`, `intent_id`, `timestamp`. Stripe never receives: account balance, transaction history, account number, or any data beyond the Boolean.

UC-02: Auto-Reload Stored Value Wallet

A consumer has linked their checking account to auto-reload a retail payment wallet when the balance drops below \$5.

1. The wallet app detects low card balance and initiates a \$25 reload.
2. App generates Intent-ID and calls `POST /balance/verify` with `amount=$25`.
3. Bank PEP atomically verifies: (a) sufficient funds, (b) fraud evaluation pass, (c) token valid. Returns `True`.
4. App calls `POST /transfer/charge`. Bank atomically re-verifies and executes.
5. Consumer receives bank notification: "\$25 authorized to [Wallet App] Auto-Reload."

Privacy Outcome

The wallet app never sees the consumer's raw balance or transaction history. Idempotency Keys prevent double-reload on network retry. Intent-ID linking proves the user authorized this specific \$25 reload.

UC-03: Fraud Flag — Blocked Verification

A verification request triggers the bank's internal fraud evaluation.

1. Finance App calls `POST /balance/verify`.
2. Bank PEP atomically evaluates. Internal fraud model flags the request.
3. PEP returns `False` to the Finance App. No reason code. No data leaked.
4. PEP simultaneously triggers `verification.blocked` webhook to the authenticated user.
5. User receives: "A verification request to your account was blocked. Review in your Connected Apps portal."
6. User opens Kill Switch portal, sees: "Stripe — Blocked (fraud review)" with timestamp and `intent_id`.
7. User optionally calls `POST /auth/token/revoke` to terminate the app's access.

Security Outcome

The Finance App never learns it was flagged — it sees only `False`, indistinguishable from an insufficient funds response. A malicious app cannot use the block signal to probe or adapt its behavior.

UC-04: Kill Switch Revocation

A consumer discovers an unauthorized app has access to their account.

1. Consumer navigates to their bank's Connected Apps portal (Kill Switch).
2. Consumer identifies the suspicious app and taps "Revoke Access."
3. Consumer's app calls `POST /auth/token/revoke` with the `ScopedAccountToken`.
4. Bank instantly invalidates the token. All pending Intent-IDs are voided.
5. Subsequent calls from the Finance App receive 403 TOKEN_REVOKED.
6. Revocation is logged in the Kill Switch portal with a timestamp.

UC-05: Agentic Financial Operation

An AI assistant is authorized to pay monthly subscriptions on the user's behalf.

7. User grants the AI agent a `ScopedAccountToken` with scope: [balance:verify, transfer:charge].
1. Agent identifies Netflix subscription due (\$15.99) and generates Intent-ID.
8. Agent calls `POST /balance/verify` for \$15.99. Receives `True`.
2. Agent calls `POST /transfer/charge`. Bank atomically re-verifies and executes.
3. Agent moves to the next subscription. Generates new Intent-ID. Repeats.
4. No agent in the chain ever sees the account balance. Each Intent-ID expires on use.

Agentic Governance Outcome

Even a compromised sub-agent cannot accumulate account state or lateral-access beyond its scoped proof. Each Intent-ID bounds the blast radius of the operation to its declared purpose.

5. Functional Requirements

5.1 Phase 1 — Clean Pipe (Required for Compliance)

FR-01: Scoped Account Token Issuance

Requirement ID	Requirement
FR-01.1	The bank MUST present an account selector UI allowing the user (not the app) to select ONE specific account.
FR-01.2	The issued <code>ScopedAccountToken</code> MUST be mathematically restricted to the selected account ID.
FR-01.3	The bank MUST generate a Persistent Account Token (<code>alias_id</code>) unique to the Finance App. The raw DDA number MUST NOT be transmitted.

FR-01.4	The account token MUST encode the user-approved consent_scope array. The bank MUST NOT honor requests for scopes not present in the account token.
FR-01.5	The bank's PEP MUST architecturally reject any request targeting an account not encoded in the token. Policy-based rejection ("app shouldn't look") is insufficient. This MUST be a hard architectural wall.
FR-01.6	Token expiry MUST be cryptographically enforced. Expired tokens MUST NOT be renewable without user re-consent.

FR-02: Composite Atomic Verification (the "is_enough" check)

Requirement ID	Requirement
FR-02.1	<code>POST /balance/verify</code> MUST perform balance verification AND fraud evaluation as a single atomic operation within the PEP. These MUST NOT be implemented as separate sequential calls.
FR-02.2	The response body MUST contain only: <code>is_enough</code> (boolean), <code>intent_id</code> (echoed), <code>evaluated_at</code> (timestamp). No other fields are permitted.
FR-02.3	A <code>False</code> response MUST be opaque. All <code>False</code> conditions — insufficient funds, fraud flag, revoked token, rate limit, cap exceeded — MUST return identical responses. Reason codes MUST NOT be surfaced to the Finance App.
FR-02.4	The endpoint MUST be rate-limited per <code>ScopedAccountToken</code> at a level sufficient to prevent binary search attacks on account balances. The implementing institution defines the specific limit. Exceeding this limit MUST return 429 and trigger a <code>verification.blocked</code> notification to the user.
FR-02.5	Each Intent-ID is single-use. A blocked verification (<code>False</code>) MUST immediately invalidate the Intent-ID. The Finance App MUST generate a new Intent-ID for any retry.
FR-02.6	A 200 HTTP status MUST be returned for all evaluated requests — including <code>False</code> results. HTTP status reflects successful evaluation, not transaction approval.
FR-02.7	The bank MUST NOT return raw balance, transaction history, account numbers, or any financial data beyond the Boolean in this or any response.

FR-03: Fraud Flag Notification Sovereignty

Requirement ID	Requirement
FR-03.1	When <code>/balance/verify</code> returns <code>False</code> due to an internal fraud flag, the bank MUST simultaneously trigger a <code>verification.blocked</code> webhook notification to the authenticated user.
FR-03.2	The webhook payload MUST include: event type, timestamp, app alias_id, intent_id, and human-readable reason (from approved taxonomy).
FR-03.3	The webhook MUST be delivered to the authenticated user's registered notification channel. It MUST NOT be delivered to or visible by the Finance App.

FR-03.4	Approved reason taxonomy: <code>approved</code> , <code>declined_insufficient_funds</code> , <code>declined_fraud_review</code> , <code>declined_rate_limit</code> , <code>declined_revoked</code> , <code>declined_cap_exceeded</code> .
FR-03.5	<code>False</code> due to insufficient funds MUST NOT trigger a webhook. Insufficient funds is a normal payment outcome, not a security event.

FR-04: Atomic Fund Transfer (POST /transfer/charge)

Requirement ID	Requirement
FR-04.1	<code>POST /transfer/charge</code> MUST perform balance verification, fraud evaluation, and fund deduction as a single atomic PEP operation. These MUST NOT be implemented as separate sequential steps.
FR-04.2	Each <code>/transfer/charge</code> call independently verifies and executes atomically. A prior <code>/balance/verify True</code> result is not required — <code>/transfer/charge</code> performs its own authoritative verification at execution time.
FR-04.3	The raw DDA account number MUST NOT appear in the request, response, or any log entry accessible to the Finance App. Transfer executes against the <code>alias_id</code> .
FR-04.4	The X-Idempotency-Key MUST be cached for a set duration (e.g. 24 hours). Retries with the same key MUST return the original response without re-executing the transfer.
FR-04.5	The <code>ScopedAccountToken</code> MUST include <code>transfer:charge</code> scope explicitly. This scope is NOT implied by <code>balance:verify</code> . The user must have explicitly consented to immediate execution at token issuance.

FR-05: Kill Switch Portal

Requirement ID	Requirement
FR-05.1	The bank MUST provide a user-facing Connected Apps portal listing all active <code>ScopedAccountTokens</code> by Finance App alias.
FR-05.2	A single user action MUST invalidate a <code>ScopedAccountToken</code> and immediately terminate the Finance App's access.
FR-05.3	The portal MUST include a transaction log with human-readable status codes for each verification and transfer event.
FR-05.4	Portal status taxonomy MUST include: <code>approved</code> , <code>declined_insufficient_funds</code> , <code>declined_fraud_review</code> , <code>declined_rate_limit</code> ,

	<code>declined_revoked</code> , <code>declined_cap_exceeded</code> . These codes MUST NOT appear in any API response to Finance Apps.
FR-05.5	Real-time Consent Receipts MUST be sent to the user after every successful transfer, detailing the amount and Consent Policy used.

5.2 Phase 2 — Risk Capping & Governance (Optional)

FR-06: Virtual Allowances

Requirement ID	Requirement
FR-06.1	The bank MAY implement time-bound and value-bound Virtual Allowances limiting cumulative spend by a Finance App within a period.
FR-06.2	The PEP MUST enforce cap logic before touching the core ledger. If the weekly/monthly cap is met, the PEP MUST reject the call with <code>False</code> (cap exceeded) before executing any balance check.
FR-06.3	<code>GET /governance/permission-budget</code> MUST return <code>remaining_budget</code> , <code>period_type</code> , and <code>period_resets_at</code> . It MUST NOT return account balance.
FR-06.4	Cap values are user-configured and institution-implemented. LDBP does not mandate specific values.

FR-07: Batch Verification and Execution

Requirement ID	Requirement
FR-07.1	<code>POST /batch/balance/verify</code> is informational only. It MUST NOT move or earmark funds. Results inform business logic but do not authorize fund movement.
FR-07.2	<code>POST /batch/transfer/charge</code> is the exclusive batch execution path. Each intent MUST be atomically verified and executed within the PEP independently. Partial success is valid — some intents may execute while others return <code>False</code> .
FR-07.3	Batch size minimum is 2 intents. Maximum batch size is institution-defined with a ceiling that balances throughput and atomic execution performance. This applies to both <code>/batch/balance/verify</code> and <code>/batch/transfer/charge</code> .
FR-07.4	<code>/batch/balance/verify</code> results are NOT consumed by <code>/batch/transfer/charge</code> . The charge endpoint performs independent atomic verification per intent at execution time.

FR-08: Bank Monetization

Requirement ID	Requirement
FR-08.1	<code>GET /billing/metering</code> MUST return per-charge and per-batch execution call counts and accrued fees for the billing period. Verification call counts (per <code>/balance/verify</code> and <code>/batch/balance/verify</code>) SHOULD be included for operational reporting purposes. Whether verification calls are billed is institution-defined.
FR-08.2	Fee rates are institution-defined. LDBP specifies the metering mechanism, not the rates.
FR-08.3	Metering data MUST NOT include account balances, transaction amounts, or user financial data. <i>Metering records MUST be used exclusively for billing attribution. They MUST NOT be used for behavioral analysis, user profiling, or any purpose beyond fee calculation and operational reporting.</i>

6. Non-Functional Requirements

NFR ID	Category	Requirement	Target
NFR-01	Performance	<code>/balance/verify</code> response time (P99)	Target: < 500ms; institution-defined based on infrastructure
NFR-02	Performance	<code>/transfer/charge</code> response time (P99)	Target: < 1000ms; institution-defined based on infrastructure
NFR-03	Availability	API Gateway uptime SLA	99.9% (Phase 1) / 99.99% (Phase 2)
NFR-04	Security	All transport encrypted	TLS 1.3 minimum
NFR-05	Security	<code>/transfer/charge</code> and <code>/batch/transfer/charge</code> require mTLS	Enforced at gateway layer
NFR-06	Security	Idempotency key cache duration	Typically 24 hours minimum
NFR-07	Rate Limiting	<code>/balance/verify</code> calls per scoped token per hour	Institution-defined; must prevent binary search attacks on account balances.
NFR-08	Auditability	All PEP decisions logged with request_id	2 years minimum for transfer records per Regulation E (12 CFR 1005.13). Institution-defined for verification-only events.

NFR-09	Privacy	No raw financial data in any log accessible to Finance App	Zero tolerance
NFR-10	Compliance	CFPB 1033 attribute-level scoping	All /balance/verify responses
NFR-11	Compliance	Regulation E notification on every transfer	Real-time webhook
NFR-12	Scalability	Batch settlement max concurrent batches	Institution-defined

7. API Surface Reference

Full specifications are defined in `ldbp_api.yaml`. This section provides the authoritative endpoint inventory and key behavioral contracts for engineering planning purposes.

7.1 Phase 1 Endpoints — Required for Compliance

Endpoint	Method	Summary	Key Behavioral Contract
<code>/auth/token/exchange</code>	POST	Issue Scoped Account Token	User selects one account. Bank issues <code>alias_id</code> — never raw DDA. Token encodes <code>consent_scope</code> . Hard architectural account restriction at PEP.
<code>/auth/token/revoke</code>	POST	Kill Switch	Instant invalidation. All pending Intent-IDs voided. App receives 403 <code>TOKEN_REVOKED</code> on all subsequent calls. User sees revocation in their Connected Apps portal.
<code>/balance/verify</code>	POST	The 'is_enough' check	COMPOSITE ATOMIC: balance + fraud in one PEP operation. Returns single Boolean. <code>False</code> is opaque — all failure modes identical from outside. Rate: follows the institution-defined max number of calls per hour
<code>/transfer/charge</code>	POST	Consolidated Verify-and-Execute	Requires mTLS. Atomic balance + fraud + deduction in single PEP operation. Requires <code>transfer:charge</code> scope. Idempotency key cached 24hr (or specified cache duration). DDA never transmitted.

7.2 Phase 2 Endpoints — Optional

Endpoint	Method	Summary	Key Behavioral Contract
----------	--------	---------	-------------------------

<code>/governance/permission-budget</code>	GET	Virtual Allowance Check	Returns remaining_budget (threshold, not balance). Period type and reset time. No account data.
<code>/batch/balance/verify</code>	POST	Batch Informational Verify	No funds moved. Per-intent Boolean results. Partial True/False results are valid. Rate limit applies across single + batch verify combined.
<code>/batch/transfer/charge</code>	POST	Batch Atomic Verify+Execute	Requires mTLS. Atomic per intent — no verify-execute gap. Partial success valid (HTTP 207). Independent of <code>/batch/balance/verify</code> results.
<code>/billing/metering</code>	GET	Fee Attribution	Per-call counts and accrued bps fees. No user financial data. Institution-defined rate.
<code>/webhooks/verification.blocked</code>	POST	Fraud Block Notification	Bank → User only. NEVER forwarded to Finance App. Triggered on fraud flag, rate limit, revocation, cap exceeded. Not triggered on insufficient funds.

7.3 Intent-ID Lifecycle

Critical: Intent-ID State Machine

CREATED (by Finance App) → CONSUMED (`/transfer/charge` or `/batch/transfer/charge` executes **True**) → [terminal]

CREATED → INVALIDATED (`/balance/verify` or `/batch/balance/verify` returns **False**, OR `/transfer/charge` returns **False**) → [terminal]

Any attempt to reuse a CONSUMED or INVALIDATED Intent-ID returns 409 INTENT_ID_CONSUMED.
The Finance App MUST generate a new Intent-ID for any retry.

7.4 False Response Taxonomy (Internal to Bank — Never Surfaced in API)

Internal False Reason	External API Behavior	Webhook Triggered?
Insufficient funds	Returns False, HTTP 200	No webhook
Fraud flag triggered	Returns False, HTTP 200	YES — verification.blocked
Rate limit exceeded (institution-defined limit)	Returns False, HTTP 429	YES — verification.blocked
Token revoked	Returns 403 TOKEN_REVOKED	YES — verification.blocked

Weekly/monthly cap exceeded	Returns False, HTTP 200	YES — verification.blocked
Intent-ID already consumed	Returns 409 INTENT_ID_CONSUMED	No webhook

8. System Architecture

8.1 The Translation & Governance Layer

LDBP does not require core ledger replacement. The implementation model is a Translation and Governance Layer — an API Gateway — that sits on top of the bank's existing core banking system (e.g. FIS, Fiserv, Jack Henry, or equivalent). This gateway intercepts all inbound requests from Finance Apps and enforces LDBP protocol before any call touches the ledger.

Architecture Principle

Finance App → [LDBP API Gateway / PEP] → [Existing Core Ledger]

The bank does not need to modify its core ledger for Phase 1. The gateway handles scoping, aliasing, Boolean wrapping, fraud evaluation routing, and idempotency caching.

8.2 Key Architectural Components

Component	Responsibility
Identity & Scoping Layer	OAuth 2.0 account-level token issuance. Account selector UI. Alias ID generation (alias_8822_stripe pattern). Consent scope encoding. Token cryptographic expiry.
Policy Enforcement Point (PEP)	The central enforcement engine. Checks consent rules, weekly/monthly caps, token validity. Routes balance check and fraud evaluation. Returns composite Boolean. Enforces opaque False responses.
Fraud Evaluation Router	Passes transaction context to the bank's internal fraud model. Result feeds into PEP's composite atomic decision. Never exposes fraud model output to Finance App.
Boolean Wrapper	Wraps the existing GET /balance ledger call. Converts raw balance integer to True/False comparison against the requested amount. Ensures no raw number leaves the gateway.
Atomic Wrapper (Stored Procedure)	Implements balance verification, fraud evaluation, and fund deduction in a single database lock within the PEP. Used by /transfer/charge and /batch/transfer/charge. Prevents race conditions.

Idempotency Cache	24-hour cache keyed on X-Idempotency-Key. Prevents double-charging on network retries. Returns original response on duplicate key.
Notification Engine	Sends verification.blocked webhooks to authenticated users. Sends Real-time Consent Receipts on transfer execution. Never routes notifications to Finance Apps.
Kill Switch Portal Backend	Manages ScopedAccountToken lifecycle. Instant revocation. Transaction log with human-readable status taxonomy. Consumer-facing only.
Billing Metering Service	Counts per-execution and per-batch execution events for billing. Tracks per-verification call counts for operational reporting. Calculates bps royalties on billable events.

8.3 Phase 1 Implementation LOE

Component	LOE	Notes
Account Selector UI & Scoped OAuth Tokens	Low–Medium	Banks already have OAuth 2.0 plumbing. Requires adding account-selector radio button to existing login flow and alias_id mapping table.
Boolean <code>/balance/verify</code> Endpoint	Medium	Simple logic gate wrapping existing GET <code>/balance</code> . PEP routes balance check + fraud evaluation. Returns Boolean only.
Atomic Check-then-Capture	Medium–High	Create stored procedures (automated database routines) that wrap the bank's existing ledger operations, ensuring balance check, fraud evaluation, and debit happen as one inseparable step. Most banks supporting RTP/FedNow already have real-time hooks; Phase 1 builds the API interface on top of them. Banks on standard ACH implement the atomic wrapper at the gateway layer.
Idempotency Key Cache	Low–Medium	Standard 24-hour key-value cache on API gateway layer.
Kill Switch Portal	Low	Revoke button added to existing Connected Apps dashboard. Portal status log is new.
Request Throttling	Low	Hard rate limit on <code>/balance/verify</code> per scoped token. Standard API gateway configuration.
TOTAL Phase 1	6–9 months	Standard API roadmap item. No core ledger replacement required.

9. Fraud Detection Architecture

9.1 Restoring the Correct Ownership Model

The all-access model created a circular fraud responsibility problem: Finance Apps inserted themselves into account-level fraud detection, then cited fraud prevention as justification for all-access data. This is a circular dependency — apps built their fraud models on data collected beyond what any individual transaction required, then cited those models as justification for continued over-collection.

The correct principle is: *fraud detection belongs to the layer that owns the asset*. Since the bank owns the account and the funds, account-level fraud belongs to the bank. The Finance App's fraud responsibility is scoped to transaction-level fraud on its own platform — not the user's broader account.

The Credit Card Precedent

Visa/Mastercard and the issuing bank own fraud detection on the account. The merchant has zero visibility into the cardholder's other transactions. Yet fraud is effectively managed. LDBP restores this clean separation for bank account transactions.

9.2 Fraud Responsibility Boundaries Under LDBP

Fraud Type	Responsible Party	Mechanism
Account-level behavioral fraud (velocity, pattern anomaly, account takeover)	Bank — internal to PEP	Bank's fraud model evaluates internally. Result feeds composite Boolean. Never disclosed to the app.
Transaction-level fraud (chargeback, friendly fraud)	Finance App	Finance App uses its own transaction-level signals (not bank account data). Idempotency Keys and Intent-IDs provide cryptographic authorization chain.
Identity verification fraud	Bank — at token issuance	User authenticates with bank at <code>/auth/token/exchange</code> . Identity is validated before a token is issued. Finance App never needs to re-verify identity.
Rate-based probing / Binary Search attacks	Bank — rate limiter	Hard limit (N calls/hour) per scoped token. <code>verification.blocked</code> notification on limit exceeded.

9.3 Transition Risk: Fraud Coverage Gap

A Phase 1 rollout does not require banks to have fully upgraded fraud detection on day one. The transition risk is real and must be planned for:

- Banks have gradually offloaded behavioral fraud detection to aggregators over time. Internal fraud models at mid-size and regional institutions may need investment.

- Core processors (FIS, Fiserv, Jack Henry) have no commercial incentive to build enhanced fraud logic. Banks may need to implement this in the gateway layer independently.
- The transition period provides a bridge: Phase 1 Boolean verification reduces data exposure immediately while bank-side fraud capability matures.

LDBP v1.0 addresses this through three mitigations:

- **Federated Fraud Signals:** Anonymized signal sharing through networks like Early Warning Services (EWS), which already runs Zelle's fraud backbone.
- **Regulatory Leverage:** CFPB 1033 and PSD3 provide the external mandate banks need to justify fraud infrastructure investment to their boards.
- **Phased Responsibility Transfer:** Deliberate design feature of the two-phase adoption model. Phase 1 establishes the architectural boundary; fraud model maturity follows.

10. Regulatory Compliance Mapping

Regulation	Requirement	LDBP Technical Implementation
CFPB Section 1033	"Reasonably necessary" data only. No secondary use. API standardization.	Attribute-Level Scoping converts "reasonably necessary" from legal assertion to technical guarantee. Boolean response makes over-collection technically impossible.
CFPB Section 1033	Revocation rights.	<code>POST /auth/token/revoke</code> provides instant cryptographic token invalidation. Kill Switch portal provides user-accessible revocation.
GDPR — Purpose Limitation	Data collected only for stated purpose. Not used for secondary purposes.	Finance App never possesses raw data. Cannot sell what it never received. Ephemeral data objects / ZKPs (Phase 2) ensure data never stored at the Finance App layer.
PSD3 / PSR (EU)	Ban on screen scraping. Dedicated secure APIs required.	LDBP provides the dedicated secure API. Boolean verification exceeds PSD3 requirements — EU APIs still return raw balances; LDBP returns only True/False.
FiDA (EU, <i>pending</i>) Currently in trilogue negotiations; implementation timeline subject to change.	Transparent consent dashboards. User can revoke with one click.	Kill Switch portal directly implements FiDA consent dashboard requirements.

Regulation E (US)	Consumer notification on electronic fund transfers.	Real-time Consent Receipts on every transfer. <code>verification.blocked</code> webhooks on blocked events.
GDPR — Data Minimization	Minimum necessary data for the purpose.	The Boolean response is the technical floor of data minimization. The protocol makes more data mathematically unavailable at the API layer.

11. Business Model & Stakeholder Impact

11.1 Bank ROI Case

LDBP converts the bank from a passive data source into an active policy enforcer and monetization layer. The commercial case has three components:

- **Revenue Recovery:** Banks currently give transaction data to aggregators for free. Under LDBP, the bank charges Finance Apps basis-point royalties on every executed transaction via `/billing/metering`, with the option to meter verification calls at institution discretion.
- **Liability Reduction:** Under CFPB 1033, banks are now responsible for the downstream behavior of every Finance App connecting via their developer interface. If the bank shares only a Boolean result rather than raw account data, a breach at a third-party fintech exposes nothing — because the fintech never received anything worth stealing. This is a direct reduction in regulatory and legal surface area.
- **Compliance Posture as Competitive Differentiation:** Banks that adopt LDBP as their CFPB 1033 interface standard can market this as a privacy-forward product feature — a meaningful differentiator in consumer trust as open banking regulations expand.

11.2 Finance App Impact

Impact Area	Effect Under LDBP
Data brokerage revenue	Eliminated. The Boolean-only response means no transaction data exists at the Finance App layer to monetize or share. Revenue streams dependent on extracted user data are not recoverable under LDBP.
Behavioral profiling for upselling	Behavioral profiling capability eliminated. No transaction history, no balance pattern, no salary cadence available to the Finance App.
Core payment processing revenue	Unaffected. Interchange, processing margins, and subscription fees do not depend on data harvesting.
Fraud liability	Reduced.

	Finance App is no longer liable for account-level data that was collected beyond what any individual transaction required. If they don't hold it, they can't lose it.
NSF decline rates	Reduced. /transfer/charge atomic execution eliminates NSF declines caused by ACH race conditions.
BNPL underwriting	Requires architectural change. Raw data access replaced by bank-mediated creditworthiness signal (designated for a future version).
Compliance cost	Reduced. Apps that never hold raw user financial data have dramatically reduced GDPR/1033 compliance surface area.
Integration Simplicity	Improved. A standardized Boolean API works identically across all LDBP-compliant banks. Finance Apps integrate once rather than maintaining separate aggregator integrations per institution.
Breach and compliance liability	Substantially reduced. Apps holding only Boolean results and transfer IDs carry minimal data breach exposure. A breach of the Finance App layer exposes nothing of financial value — no account numbers, no transaction history, no balances.

11.3 Consumer Outcomes

- Zero financial history exposure to third-party apps.
- Meaningful, user-controlled consent: one account, defined scope, instant revocation.
- Real-time transparency: notification on every transfer and every blocked event.
- Reduced identity theft surface: `alias_id` prevents DDA number from being transmitted or stored outside the bank.
- Safe bank account usage with credit-card-equivalent privacy protection.

12. Agentic Governance

12.1 Why Existing APIs Are Insufficient for Autonomous Agents

Standard open banking APIs like FDX were designed for human-initiated, session-bound interactions. An all-access token handed to an autonomous agent creates a fundamentally different threat model: the agent acts on behalf of the user across multiple systems, with no human in the loop to catch over-collection, scope creep, or cascading authorization errors. A compromised or misbehaving agent operating under an all-access token carries the blast radius of the user's entire financial life — not just the task it was dispatched to complete.

12.2 LDBP as the Correct Agentic Primitive

LDBP's scoped proof model is architecturally matched to the agentic use case in a way all-access APIs are not:

- An agent executing a \$50 grocery reorder does not need the user's account balance. It needs a Boolean confirmation that funds exist for that specific transaction, tied to an Intent-ID that expires when the task completes.
- In a Multi-Agent System, an orchestrator delegates to sub-agents. Each sub-agent receives only the verification surface it needs for its specific function — nothing persists, nothing accumulates, and a compromised sub-agent cannot laterally access account data beyond its scoped proof.
- Each agent in the delegation chain is a potential over-collection surface. LDBP's architecture ensures that the surface is bounded by the task, not the account.

Least-Privilege by Design

LDBP does not apply least-privilege to agentic systems as a policy. *It enforces least-privilege as an architectural constraint.* An agent cannot over-collect because the API physically cannot return more than a Boolean.

13. Implementation-Defined Behaviors

LDBP deliberately leaves the following behaviors to the implementing institution. This is an architectural design choice that enables adoption across institutions with different risk models, regulatory environments, and infrastructure maturity levels.

Behavior	Implementation Guidance
Fraud scoring model and flag thresholds	Institution-defined. LDBP requires only that fraud evaluation is performed atomically within POST /balance/verify and its result is reflected in the Boolean. The model, training data, and thresholds are not specified.
Consumer notification format and channel	Institution-defined. The verification.blocked webhook payload schema is specified; the delivery channel (push, SMS, email) and visual presentation are not.
Attribute verification method	Phase 1: Internal ledger comparison logic is sufficient. Phase 2 / high-value environments: Zero-Knowledge Proofs (ZKPs) are recommended as the cryptographically strongest instantiation. LDBP mandates that raw attribute data never leaves the bank — not how that guarantee is cryptographically enforced.
Weekly/monthly cap values	User-configured and institution-implemented. LDBP specifies the Virtual Allowance mechanism; specific dollar values and period definitions are not mandated.
mTLS certificate infrastructure	Institution-defined. LDBP requires mTLS for /transfer/charge and /batch/transfer/charge; the certificate authority, rotation policy, and revocation mechanism are implementation-defined.
Billing rate (basis points)	Institution-defined.

LDBP specifies the metering mechanism; the bps rate charged per verification or execution event is a commercial decision for each implementing bank.

14. Risks & Mitigations

Risk ID	Risk	Likelihood	Mitigation
R-01	Core processor resistance (FIS, Fiserv, Jack Henry have no incentive to support granular scoping)	High	Phase 1 implemented as gateway layer above core. No core modification required. Regulatory mandate (CFPB 1033) provides external pressure on processors.
R-02	Finance App objection: fraud detection degradation	High	Fraud conflation argument addressed in FR-02 and Section 9. Apps conflate account-level fraud (bank's) with transaction-level fraud (app's). Identical to credit card model.
R-03	Bank fraud detection infrastructure gap at Phase 1 launch	Medium	Phased responsibility transfer is a deliberate design feature. Transition period coexistence with app-layer models. EWS federated fraud signals is designated for a future version.
R-04	Binary Search balance probing attack	Medium	Implement a hard rate limit. Noise injection (probabilistic True near threshold). Threshold randomization. Rate limit breach triggers verification.blocked notification.
R-05	Race condition on non-RTP/FedNow networks	Low	Eliminated by design. /transfer/charge atomically re-verifies at execution time — there is no verify-execute gap. No stale verification state can be exploited.
R-06	BNPL underwriting disruption	Medium	Instant micro-lending services rely on user transaction patterns and history to make fast underwriting decisions. LDBP makes this impossible under the current all-access model. This is an acknowledged legitimate hard case. A bank-mediated creditworthiness signal (is_debt_ratio_acceptable) is designated for a future LDBP version.
R-07	Regulatory uncertainty on ZKP mandate	Low	ZKP scoped as Phase 2 optional. Phase 1 compliance achievable with internal comparison logic. ZKP is the cryptographically strongest instantiation, not the minimum viable one.
R-08	Agentic prompt injection targeting financial operations	Medium	Intent-ID binding limits blast radius per operation. ScopedAccountToken restricts agent to declared account. Each operation independently verified — no accumulated state exploitable.

15. Success Metrics

Metric	Definition	Target / Threshold
Raw Data Extraction Rate	% of <code>/balance/verify</code> responses containing any field beyond <code>is_enough</code> , <code>intent_id</code> , <code>evaluated_at</code>	0% — Zero tolerance
False Opacity Compliance	% of <code>False</code> responses that include any reason code or distinguishing signal in the response body	0% — Zero tolerance
Notification Sovereignty	% of <code>verification.blocked</code> events where webhook was delivered to user (not app) within 5 seconds	> 99.5%
Phase 1 LOE	Calendar months from project kickoff to first production-compliant <code>/balance/verify</code> response	≤ 9 months
Kill Switch Latency	Time from <code>POST /auth/token/revoke</code> to Finance App receiving 403 <code>TOKEN_REVOKED</code> on next call	< 1 second
Idempotency Correctness	% of retry attempts on a consumed idempotency key that result in duplicate transfer execution	0% — Zero tolerance
Atomic Execution Rate	% of <code>/transfer/charge</code> and <code>/batch/transfer/charge</code> calls implemented as single-database-lock atomic PEP operations	100% — Protocol requirement
Consumer Consent Receipt Delivery	% of successful transfers followed by user notification within 30 seconds	> 99%
Bank Monetization Adoption	% of LDBP-compliant banks with active <code>/billing/metering</code> usage by 12 months post-launch	Aspirational: 60% within 12 months post-launch. No conformance implication.

16. Future Work

The following capabilities are out of scope for the current release and designated for future LDBP versions (major or minor release). Implementers and researchers are invited to contribute proposals via the GitHub repository.

- **Federated Fraud Signal Standard:** Formal specification for anonymized fraud signal exchange between banks via EWS-compatible networks. Enables collective fraud intelligence without account-level data sharing.
- **Cryptographic Threshold Hardening:** Formal ZKP integration patterns for attribute verification. Proof schemes optimized for Phase 1 performance constraints (< 500ms P99).
- **Cross-Institution Alias Portability:** Standards for alias_id and Intent-ID coordination across multiple banks and payment networks. Enables multi-bank user scenarios.
- **BNPL Creditworthiness Signal:** Bank-mediated scoped proof specification for underwriting use cases (e.g., is_debt_ratio_acceptable). Supports BNPL instant-credit without raw data transfer.
- **Agentic Authorization Standard:** Formal Intent-ID lifecycle specification for multi-agent delegation chains, including sub-agent scope inheritance and revocation propagation.
- **OpenID Connect Integration:** LDBP-compliant OIDC profile for banks already operating OIDC identity infrastructure.

Appendix A — Glossary

Term	Definition
All-Access Model	The current dominant paradigm in open banking: aggregators extract full account history, all accounts, and raw balances under a persistent, scope-unlimited token.
Alias ID (alias_id)	An opaque, app-specific identifier generated by the bank as a substitute for the raw DDA account number. Safe to transmit — reveals nothing about the underlying account.
Atomic Wrapper	A stored procedure that performs balance verification, fraud evaluation, and fund deduction in a single database lock, preventing race conditions.
Boolean Verification	The 'is_enough' check. The practice of returning a True/False result to a threshold query rather than a raw numeric value.
Direct Deposit Account (DDA)	The 12-digit permanent account number banks use internally. LDBP ensures the DDA is never transmitted to Finance Apps.
Intent-ID	A session-based, single-use UUID generated by the Finance App for each transaction. Used by /balance/verify (informational) and /transfer/charge (execution). Invalidated on False verification or on consumption by a charge.
Kill Switch	The user-facing portal action (POST /auth/token/revoke) that instantly invalidates a ScopedAccountToken and terminates Finance App access.
Least Data Banking Protocol (LDBP)	The Privacy-by-Design API framework specified in this document.
Non-Sufficient Funds (NSF)	A condition in which a bank account does not hold enough funds to cover a requested transfer. NSF decline rates are reduced under LDBP because /transfer/charge atomically re-verifies at execution

	time, eliminating the race condition gap between balance check and debit that causes most NSF failures under standard ACH.
Notification Sovereignty	The architectural principle that blocked verification events are delivered "bank → user directly", never "bank → app → user." Apps receive only False .
Policy Enforcement Point (PEP)	The bank's internal service that enforces LDBP rules — consent logic, cap checks, fraud evaluation routing — before any call touches the core ledger.
PSD3 (Payment Services Directive 3) / PSR (Payment Services Regulation)	The European Union's updated payment services regulatory framework, successor to PSD2. PSD3 and the accompanying Payment Services Regulation ban the practice of screen scraping — using a user's bank login credentials to extract account data — and require banks to provide dedicated, secure APIs for financial data access. LDBP exceeds PSD3 requirements by implementing Boolean-only verification, whereas PSD3-compliant APIs still typically return raw balances. Currently in active legislative progress as of April 2026.
Scoped Account Token	The Persistent Account Token (Alias) issued by /auth/token/exchange . Mathematically restricted to a single user-selected account at a single bank.
Translation & Governance Layer	The API Gateway implementing LDBP that sits on top of the bank's existing core ledger. Phase 1 does not require core ledger modification.
Virtual Allowance	A Phase 2 feature: a time-bound and value-bound spending limit configuring the maximum cumulative amount a Finance App can draw from the scoped account in a given period.
Zero-Knowledge Proof (ZKP)	A cryptographic method allowing one party to prove a statement is true without revealing the underlying data. Recommended for Phase 2 high-value environments.

Appendix B — Document History

Version	Date	Summary of Changes
LDBP PRD v1.0	April 2026	Initial public release. Full Phase 1 and Phase 2 requirements. Fraud detection architecture. Regulatory compliance mapping. Agentic governance. Aligned to LDBP API Spec v1.0.0 and Whitepaper v1.0 RFC.

Contributing

LDBP is published under CC BY 4.0. Attribution to Mary Ann Belarmino and BelarminoAdvisory.com is required on all uses, implementations, derivative works, and references. For commercial licensing inquiries or partnership discussions: BelarminoAdvisory.com. Implementation feedback, technical proposals, and use case contributions are invited via the GitHub repository.

This document contains original protocol architecture and design authored by Mary Ann Belarmino (BelarminoAdvisory.com) and licensed under Creative Commons Attribution 4.0 International (CC BY 4.0). You are free to share and adapt this work for any purpose, including commercial, provided attribution to Mary Ann Belarmino and BelarminoAdvisory.com is clearly stated. Attribution must be preserved in all copies, implementations, derivative works, and references.